

감사보고서

- 2024년도 정보보안 감사 -

2024. 10.

전력거래소
감사실

I 감사 개요

1. 감사배경

가. 관련규정 : 국가정보보안기본지침 제8조(정보보안감사 등)

- 각급기관의 장은 해당 기관 및 관할 하급기관의 정보보안업무 및 활동을 조사·점검하기 위하여 연1회 이상 정보보안감사를 실시하여야 함

2. 감사개요

가. 감사명 : 2024년도 정보보안 감사

나. 감사기간

- 감사기간 : '24.9.23. ~ 10.18.
 - 감사안내 및 임직원의 자발적 보안조치 : '24.9.23.(월) ~ 10.10(목)
 - 보안위규사항 원격점검 : '24.10.11.(금)
 - 위규사항 확인 및 결과 통보 : '24.10.15.(화)
 - 이의 신청 : '24.10.16.(수) ~ 10.18.(금)

다. 감사대상

- 전직원 내·외부망 PC 등의 정보보안 및 개인정보 보호 관리실태(22개 항목)

라. 감사 중점사항 및 주안점

- 내PC지키미 이행실태, 개인정보 파일 관리사항 등 보안위규 확인

3. 감사방법

가. 감사방법

- 백신관리솔루션 등 자동화 점검도구를 활용한 원격 전수 점검

4. 감사반 편성 및 분장업무

구성	직책	성명	분장업무
감사반장	감사실장		감사 총괄
감사반원	감사차장		감사 시행
	정보보안실 실장		감사 지원
	정보보안실 차장		감사 지원
	정보보안실 사원		감사 지원

II

감사내용

1. 감사항목 : 22개 항목 (세부내역 불임1)

가. 개인PC 필수 보안항목 : 17개

나. 보안솔루션 및 외부망 문서편집기 임의사용 : 2개

다. 공유폴더 및 복합기 보안설정 항목 : 2개

라. 개인정보 파일 보안조치 항목 : 1개

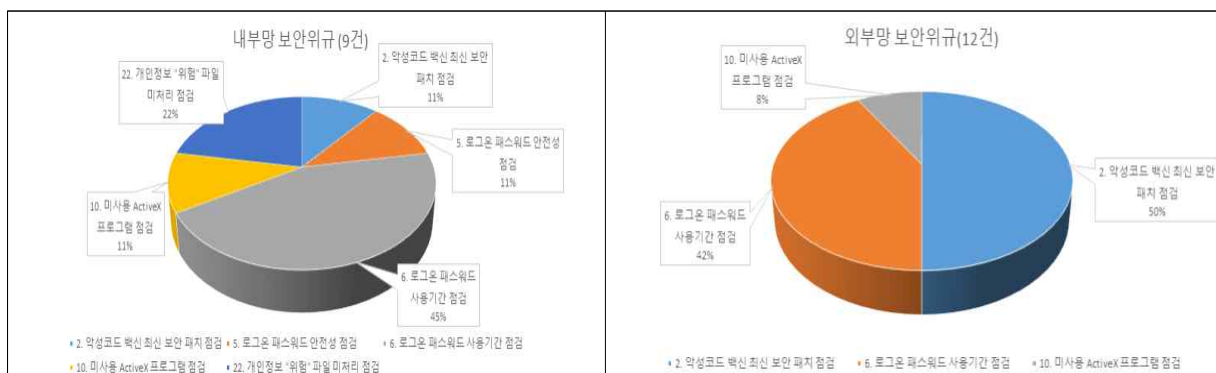
2. 확인사항

가. 보안위규 확인내역 : 총 17명, 21건 위규 확인

내부망 보안위규		외부망 보안위규	
2. 악성코드 백신 최신 보안 패치 점검	1건	2. 악성코드 백신 최신 보안 패치 점검	6건
5. 로그인 패스워드 안전성 점검	1건	6. 로그인 패스워드 사용기간 점검	5건
6. 로그인 패스워드 사용기간 점검	4건	10. 미사용 ActiveX 프로그램 점검	1건
10. 미사용 ActiveX 프로그램 점검	1건		
22. 개인정보 "위험" 파일 미처리 점검	2건		
계	9건	계	12건

나. 위규사항 분석

- 위규 확인 17명 이외의 대상인원 96% 이상은 정보보안 및 개인정보 관리 수준 우수
- 상시 업무를 수행하는 내부망 대비, 외부망의 보안조치가 미흡
 - 내·외부망 공통으로 로그인 패스워드 변경(3개월) 미흡 사례 다수 발생
 - 내부망의 경우, 개인정보 보유 파일에 대한 보안조치 강화 필요
 - 외부망의 경우, 백신 보안패치에 대한 관리 강화 필요



Ⅲ 감사 결과

1. 주요내용

- 가. 본 감사는 전사 임직원 내·외부망 PC에 대한 보안관리 실태 감사로써 총 22개의 정보보안 관리 항목에 대해 점검하였으며, 그 결과 총 21건의 내·외부망 보안관리 미흡사항을 확인하였다. 이는 로그인 패스워드 변경 기간(3개월) 초과, 개인정보 파일 암호화 미처리 등의 위규사항들이었다.
- 나. 해당 위규사항들은 징계양정업무세척에서 정하고 있는 「정보보안 위규자에 대한 징계양정 요구기준」(붙임1)에 해당하지는 않는 것으로 판단된다. 그러나, 전력거래소에서 운영하고 있는 지침 중 「정보보안 정책위반(경미한 사항)처리기준」(붙임2)의 위반사항에는 해당하는 것으로 판단된다. (붙임2)
- 다. 이와 같은 경미한 정보보안 위규사항도 중대 정보보안 침해사고로 연결되는 시발점이 될 수 있는 만큼, 지속적인 보안관리 강화와 임직원의 보안인식 제고를 위한 노력이 필요하다고 판단된다.

2. 조치사항 : 행정상 조치(통보 1건)

가. 통보 1건

부서	내용	조치요구
정보보안실	·정보보안 위규자(붙임 3) 17명에 대한 재발 방지 조치 시행 - 내부평가 반영 및 교육 등을 통한 보안인식 제고방안 강구	통보

지적건명	정보보안 위규자에 대한 재발 방지 조치 시행				
지적번호	행정상 조치	신분상 조치		재정상 조치	
		구분	인원	구분	금액
1	통보	-	-	-	-
1. 지적내용 본 감사에서는 22개 항목의 정보보안 관리 항목에 대한 점검을 시행하였습니다. 그 결과 대상자 17명에 의한 21건의 경미한 정보보안 위규사항을 확인할 수 있었습니다. 비록 해당 사항들이 경미한 정보보안 위규사항이기는 하나 경미한 위규사항도 중대한 정보보안 침해사고로 이어질 수 있는 만큼 해당 위규사항에 대한 적절한 조치가 필요할 것으로 판단됩니다. 2. 조치할 사항 이에 정보보안실장은 정보보안 감사결과 정보보안위규사항이 확인된 17명에 대하여 재발 방지를 위한 조치를 강구하시기 바랍니다.					
관련자	직위	성명	업무기간	조치내용	조치부서
조치					
조치부서	정보보안실				
관련부서					

(붙임1)

● 징계양정세척, 4. 정보보안 위규자에 대한 징계양정 요구기준

구 분		중비위 + 고의	중비위 + 중과실 또는 경비위 + 고의	중비위 + 경과실 또는 경비위 + 중과실	경비위 + 경과실
정보보안 위규 사항	양 정	해임 ~ 정직	정직 ~ 감봉	감봉 ~ 견책	견책 ~ 주의
	적용기준	○ 악의적 위해 행위 - 내부시스템의 악의적 해킹 - 시스템에 고의적 악성코드 유포 - 고의적 비밀자료 무단 유출	○ 고의적 정보보안 정책 및 절차 위반 등 - 노트북, USB 등의 작위적 망간 혼용 - 타인계정 무단 유출로 인한 피해 야기 - 고의적 비밀번호 누설 - 정보시스템 고의적 장애 유발 - 보안시스템 고의적 유기 - 비밀자료 분실 후 고의적 미신고	○ 중과실 기인 위규 등 - 비밀 분실 인지 후 미신고 - 중과실에 의한 정보시스템 손괴 - 비밀용 저장매체 무단 반출 - 자료공유사이트 통한 대량 업무자료 무단 유출 - 악성코드 감염으로 심각한 피해 유발 - 해킹피해 미신고로 추가 피해 유발	○ 경미한 정보보안 정책 위반 - 정보시스템 무력화 기법 전파 - 필수 보안프로그램 인위적 미설치 - 비인가 무선통신 무단 설치 및 사용 - 상습적 정보보안 지침 및 절차 위반 - 미승인 프로그램 무단설치로 인한 피해 야기 - 상습적 악성코드 감염 - 유해사이트 접속으로 악성코드 전파
개인정보 보호 위규 사항	양 정	해임 ~ 정직	정직 ~ 감봉	감봉 ~ 견책	견책 ~ 주의
	적용기준	○ 주민등록번호 무단 유출 및 부정 사용 ○ 인위적 개인정보 변경, 말소로 심각한 지장 초래	○ 개인정보 무단 유출 및 부정 사용 ○ 동의없이 고유식별정보수집 및 부정 사용 ○ 동의없이 민감정보 수집 및 부정 사용	○ 개인정보 대량 유출 ○ 부정한 목적으로 CCTV 임의 조작 ○ 부정한 목적으로 개인정보 제3자 제공 ○ 문서에 의하지 않고 임의로 개인 정보 처리 위탁	○ 중요자료 암호화 미실시로 자료 유출 ○ 관리소홀로 인한 중요 개인정보 유출 ○ 동의 없이 개인정보 무단 수집 ○ 법률에 의하지 않고 주민등록번호 수집

(붙임2)

● 정보보안 정책 위반(경미한 사항) 처리기준

위반 사항	처리 기준
① 내.외부망 일반PC, VDI 비밀번호 설정 미 조치 - 비밀번호 문자, 숫자, 특수문자 조합 9자리 이상 ※ 일반PC 사용자 : 화면보호기 대기시간 10분 이하 설정 및 CMOS 비밀번호 설정 ② 최신 보안 패치 적용 미 조치 - 백신SW, Internet Explorer, 문서편집기(한글, 오피스) 최신 패치 - Adobe Flash Player, JAVA 등(설치된 사용자 대상) ※ 한글의 경우 개별 팝업창이 뜰 시 '확인'버튼을 눌러 업데이트 ③ PC용 보안솔루션 설치 미 조치 - 내부망(3개) : APC(V3), SafePC, SecuPrint - 외부망(4개) : APC(V3), SafePC, SecuPrint, DaLOC(SCA Manager) ※ 일반PC 사용자 : 내.외부망 각각 NAC(Genian) 설치 필요 ④ 공유폴더 설정 해제 미 조치 - 자료공유 및 프린터기 사용을 위한 공유폴더 사용 금지 ⑤ 개인정보파일(이미지 파일 포함) 암호화 또는 삭제 미 조치 (내부망) 주요 개인정보파일(이미지 파일 포함) 암호화/삭제 (외부망) 개인정보파일(이미지 파일 포함) 삭제 - 주요 개인정보 : 고유식별정보, 바이오정보, 민감정보, 비밀번호 ※ 고유식별정보 : 주민등록번호, 여권번호, 외국인등록번호, 운전면허등록번호 ※ 바이오정보 : 홍채, 지문 등 ※ 민감정보 : 현저한 사생활 침해 정보(사상, 신체, 재산, 성생활 등) ⑥ 불필요 프로그램 및 업무자료 삭제 미 조치 (내부망) 비인가 불법 소프트웨어, 영화 및 게임 파일 삭제 대외비성 자료 암호화/삭제, 불필요 과거 업무자료 암호화/삭제 (외부망) 업무 관련 문서 및 이미지 파일 삭제, 압축(ZIP 파일 등)하여 보관중인 업무자료 삭제, 카카오톡 삭제 ⑦ 복합기 스캔용 비밀번호 및 삭제주기 설정 미 조치 - 스캔을 위한 개인별 비밀번호 설정 및 삭제주기 설정 ※ 설정 방법 : "복합기 메일박스 비밀번호 설정 알림"참조	■ 정보보안 동영상 시청 후 교육결과 보고서 제출 ■ 내부평가 보안강화 노력도 감점 : $\Sigma(\text{건수} \times 2)$ 점
⑧ 악성 이메일 (모의)훈련시 이메일 열람자 ※ 열람 후 20분 이내 미신고자	■ 정보보안 동영상 시청 후 교육결과 보고서 제출 ■ 내부평가 보안강화 노력도 감점 : $\Sigma(\text{건수} \times 1)$ 점 ■ 부서장이 직접 정보보안 교육 후 교육결과 보고서 제출 ■ 내부평가 보안강화 노력도 추가 감점 : $\Sigma(\text{건수} \times 3)$ 점
⑨ 산업부, 국정원, 행안부 등 외부기관 정보보안 및 개인정보보호 점검시 피 지적자	■ 부서장이 직접 정보보안 교육 후 교육결과 보고서 제출 ■ 내부평가 보안강화 노력도 감점 : $\Sigma(\text{건수} \times 3)$ 점

※ 보안 위규자자가 보안교육/보고서 미제출시 내부평가 보안강화 노력도 추가 감점 : 해당 항목 감점 점수로 적용(① ~ ⑦ : 2점, ⑧ : 1점, ⑨ : 3점)

※ 적용 기준 : 개인을 대상으로 적용

(붙임3)

● 정보보안 위규자 명단(17명)

연번	성명	사번	소속팀
1			팀
2			팀
3			팀
4			팀
5			팀
6			팀
7			팀
8			팀
9			팀
10			팀
11			팀
12			팀
13			팀
14			팀
15			팀
16			팀
17			지사



한국전력거래소



수 신 내부결재

(경유)

제 목 공공기관 경영정보 공개를 위한 감사결과 공시사유 발생일 검토

공공기관 경영정보 공개시스템(공공기관 알리오)의 내부 감사결과 공개를 위한 감사결과 제심의 신청을 고려한 공시사유 발생일을 다음과 같이 검토합니다.

1. 감사명 : 2024년도 정보보안감사
2. 처분사항
 - 행정상조치 : 통보 1건
3. 행정상조치 요구일 : 2024.10.22 (문서시행일 기준)
4. 인사위원회 개최여부 : 신분상조치 요구가 없어 인사위원회 미개최
 - 상벌규정 미적용, 행정상조치에 대해 감사규정 이의신청 관련규정 적용
5. 관련규정 : 감사규정 제21조 제1항 (이의신청 및 처리)

제21조(이의신청 및 처리) ① 이사장 또는 집행부서의 장이 제18조의 규정에 의한 감사 또는 감사실장의 시정요구에 대하여 이의가 있을 때에는 그 사유를 명백히 하고 관계증빙서류를 첨부하여 시정요구를 받은 날로부터 15일 이내에 감사 또는 감사실장에게 이의신청을 할 수 있다.

6. 공시 사유발생일 : 2024.11.06.
 - 행정상조치 요구일(문서시행일 기준) : 2024.10.22
 - 감사규정 제21조에 따른 이의신청기간 15일 부여
 - 민법 제157조에 따라 초일 불산입
 - 2024.11.06.까지 이의신청사항 없음. 끝.

차월 11/06 일월 11/06

편조자

감사

시할 감사실-1408 () 전수 ()
우 58922 전라남도 나주시 빽가합로 625 (빽가합동) / <https://www.kpx.or.kr>
전화 061-330 / 전수 061-330- / @kpx.or.kr / 비공개